

INTERNAL AUDIT REPORT

Audit Title: Security Monitoring and Log Management Compliance
Standard Audited: ISO/IEC 27001:2022
Audit Date: May 10, 2026
Auditor: Jandry Cabezas - GRC Analyst / Internal Auditor

1. Executive Summary

An internal audit was conducted to evaluate the effectiveness of the organization's security monitoring and log management processes against ISO/IEC 27001:2022 standards. While the centralized SIEM infrastructure is robust and actively monitored by the SOC, a significant gap was identified in log ingestion from the virtualized DMZ environment. This blind spot limits the organization's ability to detect lateral movement or brute-force attacks in that network segment. Management has agreed to the findings and provided a remediation plan.

2. Scope and Objectives

Scope: Review of log generation, retention, protection, and forwarding mechanisms across all tier-1 virtualized servers (VMware cluster) to the centralized Wazuh SIEM platform.

Objectives:

1. Verify compliance with controls A.8.15, A.8.16, and A.8.17.
2. Ensure the SOC has continuous, uninterrupted visibility over authentication and security events.

3. Audit Methodology

- **Interviews:** Conducted walkthroughs with IT Operations and SOC Lead.
- **System Review:** Sampled 30 virtual machines from the primary cluster to verify agent installation and log forwarding status.
- **Configuration Review:** Examined NTP server configurations and SIEM ingestion dashboards.

4. Audit Findings

FINDING ID: AUD-2026-01

Title: Incomplete Log Forwarding in Virtualized DMZ Segment
Severity Level: HIGH
ISO 27001 Control: A.8.15 (Logging) and A.8.16 (Monitoring activities)

Condition (What was found): During the sampling of 30 virtual machines located in the DMZ cluster, it was discovered that 6 servers (20% of the sample) are not forwarding security and authentication logs to the centralized Wazuh SIEM. The security agents on these endpoints were either offline or misconfigured.

Criteria (What should be happening): Control A.8.15 requires that event logs recording user activities, exceptions, faults, and information security events be produced, kept, and regularly reviewed. The internal ISMS policy dictates 100% log ingestion for all tier-1 assets.

Root Cause: The automated provisioning script used by IT Operations to deploy new virtual machines failed to initialize the SIEM agent service upon boot. There is currently no automated reconciliation process between the hypervisor inventory and the SIEM active agent list.

Risk/Impact: Without centralized log ingestion, the SOC has a critical visibility blind spot. If a threat actor compromises one of these DMZ servers via brute force or credential stuffing, the attack will not generate alerts, significantly increasing the Time to Detect (TTD) and allowing potential lateral movement.

Recommendations:

1. **Immediate:** Manually configure and restart the security agents on the affected DMZ servers to restore log flow.
2. **Short-Term:** Update the VM provisioning scripts to include a validation check that confirms the agent is actively communicating with the SIEM before deploying the server to production.
3. **Long-Term:** Implement an automated daily reconciliation report comparing the active virtual machine inventory against the SIEM active agent dashboard to quickly identify offline endpoints.

Management Response & Action Plan:

- **Action:** IT Operations will update the provisioning templates and manually fix the 6 identified servers. The SOC will configure an alert for when an agent heartbeat is lost for more than 15 minutes.
- **Owner:** IT Operations Manager / SOC Manager
- **Target Completion Date:** May 25, 2026

5. Conclusion

The organization demonstrates a strong commitment to continuous monitoring; however, the lack of automated validation during server provisioning introduces unnecessary risk. Addressing the identified finding will close the visibility gap and ensure full compliance with ISO 27001:2022 monitoring requirements.